

Clase 334 — Reconocimiento y escaneo asistidos por IA

Parte: **18 — IA aplicada a la ciberseguridad** · Fuente: kali-mcp (MIT) · MITRE ATT&CK (Reconnaissance) 🕒 Duración estimada: **100 min** · Nivel: **Avanzado**

⚠️ **Solo objetivos autorizados/propios.** El reconocimiento activo genera tráfico que puede ser ilegal contra sistemas ajenos. Practica únicamente en tu laboratorio o con permiso escrito.

🎯 Objetivo

Ver cómo un agente de IA coordina las fases de **reconocimiento y escaneo** (descubrimiento de hosts, puertos, servicios, subdominios) usando kali-mcp, y —lo más importante— cómo el profesional **valida** los resultados y evita que la IA saque conclusiones falsas o toque objetivos fuera de alcance.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

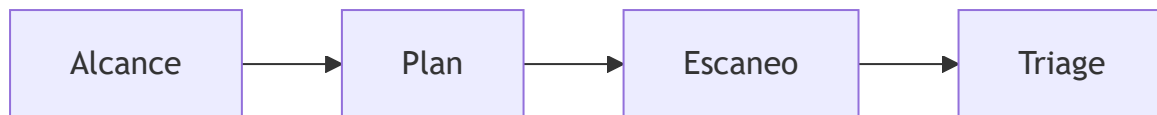
- 1. **Encadenar** recon pasivo → activo con apoyo de un agente.
- 2. **Interpretar** cómo la IA resume salidas de nmap/gobuster/enumeración.
- 3. **Validar** los hallazgos del agente contra la salida cruda de la herramienta.
- 4. **Controlar** el alcance y el ritmo (rate) para no salirse de lo autorizado.
- 5. **Documentar** la superficie de ataque descubierta de forma reproducible.

📖 Temas

#	Tema	Por qué importa
1	Recon pasivo vs activo	El pasivo no toca al objetivo; el activo, sí (y hay que autorizarlo).
2	Orquestación de escaneo	El agente lanza y correlaciona varias herramientas.
3	Comandos de flujo (kali-recon, kali-mass-scan)	Playbooks que automatizan el descubrimiento.
4	Validación de resultados	Contrastar el resumen de la IA con la salida real.
5	Alcance y ritmo	Evitar tocar lo no autorizado o saturar la red.

💡 Explicación en profundidad

La IA puede ordenar inventario y sugerir siguientes pruebas; no amplía alcance ni valida banners. Cada comando se deriva de una pregunta, pasa por política y produce artefactos reproducibles.



El diagrama separa lenguaje de autoridad. El modelo puede proponer; la política determina si la operación pertenece al alcance; la herramienta produce evidencia; y una persona o control determinista decide transiciones de alto impacto. Se registran prompt relevante, parámetros validados, versión, salida, aprobador y cleanup sin almacenar secretos innecesarios.

Caso razonado

Nmap muestra versión probable. El agente la trata como hipótesis y verifica en fuente y configuración antes de asociar vulnerabilidad.

Glosario operativo

Término	Definición
Plan de colección	Conjunto acotado de observaciones ligado a una pregunta.
Guardrail	Capa que reduce una capacidad o detecta su uso; no garantía absoluta.
Audit trail	Registro ordenado de solicitudes, decisiones, ejecuciones y resultados.

Criterio de dominio

El alumno demuestra dominio cuando reproduce el flujo completo, puede atribuir cada acción, evita que texto no confiable otorgue autoridad y explica qué control contiene un fallo del modelo.

Definiciones y características

Reconocimiento pasivo : Obtener información sin interactuar directamente con el objetivo (OSINT, DNS público). No genera tráfico hacia el objetivo.

Reconocimiento activo : Interacción directa (escaneo de puertos, enumeración). Genera tráfico y requiere autorización.

Correlación asistida : Capacidad del agente de unir resultados de varias herramientas (puertos + servicios + versiones) en una vista de la superficie de ataque.

Validación cruzada : Comprobar un hallazgo del agente ejecutando manualmente la herramienta subyacente (p. ej. confirmar un puerto con `nmap -p`).

Herramientas y preparación

kali-mcp montado (clase 333) contra una VM propia. Herramientas orquestadas típicas: nmap, gobuster/ffuf, enum4linux, dnsx. Ten abierta la terminal de Kali para **verificar a mano**.

Laboratorio guiado

Contra tu VM de laboratorio, dentro del alcance declarado.

1. **Recon pasivo.** Pide al agente un resumen de la información pública del objetivo (en el lab, será mínima). Observa qué infiere y qué inventa.
2. **Descubrimiento de hosts/puertos.** Ejecuta el flujo de escaneo y revisa la lista de puertos/servicios propuesta.
3. **Validación.** Elige 3 hallazgos y confírmalos manualmente en la terminal (`nmap -sV -p <puertos>`). ¿Coinciden?
4. **Enumeración de servicios.** Pide enumeración de un servicio concreto y contrasta con la salida cruda.
5. **Mapa de superficie.** Documenta la superficie de ataque descubierta (host, puerto, servicio, versión, evidencia).

Ejercicios

1. Diferencia recon pasivo y activo con un ejemplo de cada uno.
2. ¿Qué riesgo hay si el agente "asume" una versión de servicio que no verificó?
3. Diseña un límite de ritmo (rate) para no saturar una red de laboratorio.
4. ¿Cómo confirmarías un subdominio que el agente afirma haber encontrado?
5. Redacta la sección "superficie de ataque" de un informe a partir del recon.

Reto verificable

Con el agente, mapea la superficie de ataque de tu VM y entrega una tabla host/puerto/servicio; valida manualmente al menos el 50% de las entradas.

Criterio de aceptación: cada entrada validada coincide con la salida real de la herramienta; señalas cualquier hallazgo del agente que no pudiste confirmar (posible falso positivo).

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
El resumen del agente omite un puerto abierto	La IA puede resumir de más. Revisa la salida cruda completa.
El agente "descubre" servicios inexistentes	Alucinación o mala lectura. Valida a mano.
Escaneo alcanza IPs fuera de alcance	Redefine el scope; nunca amplíes sin autorización.
Escaneo demasiado agresivo	Ajusta timing/rate; en un lab compartido puedes tirar servicios.

? Preguntas frecuentes

? **¿La IA hace el recon más rápido?** Sí, sobre todo correlacionando salidas y sugiriendo siguientes pasos. Pero la validación sigue siendo tuya: un recon con datos falsos arruina todo el pentest.

? **¿Puedo dejar que escanee solo?** El escaneo activo debería requerir tu aprobación y un alcance claro. No lo dejes correr sin supervisión contra nada que no sea tu laboratorio.

🔗 Referencias

- MITRE ATT&CK — Reconnaissance (TA0043)
- kali-mcp (MIT) — <https://github.com/pabpereza/kali-mcp>
- Clases 029–033 (Nmap y enumeración) del programa.

📄 Material descargable

- 📄 [Guía en PDF](#) — versión imprimible de esta clase.
- 🖥️ [Presentación \(PPTX\)](#) — deck para proyectar en clase.

⬅️ Clase anterior

Clase 333 — kali-mcp: orquestar herramientas de Kali desde un agente de IA

➡️ Siguiente clase

Clase 335 — Explotación y post-explotación autorizada asistida por IA